

ZENITH ORBITAL SYSTEMS

Cloud Service Provider Management Policy

Effective: March 28, 2026 | Next Review: March 2027 | Version 1.0

Prepared by: Noe Valencia, PSSE

1. Purpose

This Cloud Service Provider Management Policy establishes standards and requirements for the selection, onboarding, security assessment, ongoing monitoring, and offboarding of all cloud service providers (CSPs) and SaaS applications used by Zenith Orbital Systems. ZOS relies on cloud infrastructure for satellite data relay operations, mission telemetry backup, collaboration, and administrative functions. The security of those cloud environments is directly connected to ZOS mission assurance.

This policy ensures that all cloud services used by ZOS meet defined security standards before onboarding, maintain those standards throughout the relationship, and are securely offboarded when no longer required. It aligns to the SANS/CRF CSP Management Policy Template (February 2026), CIS Controls v8, NIST CSF 2.0, and FedRAMP authorization requirements relevant to ZOS defense client obligations.

2. Scope

This policy applies to all ZOS personnel responsible for selecting, contracting, managing, or using cloud services. It covers all cloud deployment models and service types:

- Infrastructure as a Service (IaaS): AWS, Azure, GCP, and other cloud hosting environments
- Platform as a Service (PaaS): Cloud databases, development platforms, container services
- Software as a Service (SaaS): Microsoft 365, Splunk Cloud, Okta, CyberArk, Huntress, KnowBe4, Qualys, Archer, Zscaler, and all other subscription software services
- Any third-party managed service that stores, processes, or transmits ZOS data

3. Principle Statement

ZOS treats cloud service providers as extensions of the ZOS security perimeter. No CSP is trusted by default. Every provider must demonstrate security capability before accessing ZOS data, and that capability must be continuously validated throughout the relationship. The responsibility for ZOS data never transfers to a CSP; ZOS retains accountability for data protection regardless of where data resides.

4. Senior Management Commitment

Signed: _____ Date: _____

Chief Information Security Officer / Senior IT Leadership, Zenith Orbital Systems

5. CSP Onboarding Requirements

No new cloud service provider may be onboarded to ZOS systems without completing the following steps:

- 1. Formal security assessment of the prospective CSP using the ZOS vendor security questionnaire. The assessment must evaluate: SOC 2 Type II certification status; encryption standards for data in transit and at rest; incident response and breach notification SLAs; data residency and sovereignty requirements; subprocessor disclosure and management; penetration testing history; and compliance certifications relevant to ZOS obligations (FedRAMP, ISO 27001, CMMC).
- 2. IT Security Manager review and written approval of the security assessment findings.
- 3. Legal review and execution of a Data Processing Agreement (DPA) or equivalent contractual instrument defining data handling obligations, breach notification requirements (72 hours maximum), and ZOS audit rights.
- 4. Documentation of the CSP in the ZOS cloud service inventory with designated business owner, data classification of data shared, and next review date.
- 5. Technical onboarding including SSO integration with Okta, MFA enforcement verification, API key management via approved PAM system, and CASB integration where applicable.

6. Ongoing CSP Monitoring Requirements

Control ID	Requirement
CSP-01	Maintain a complete, current inventory of all authorized ZOS cloud services including provider name, service type, data classification, business owner, contract expiration, and certification status.
CSP-02	Review the security posture of all Tier 1 CSPs (those handling sensitive or mission-critical ZOS data) at minimum annually. Reviews must include updated SOC 2 reports, security certification renewals, and vendor-provided breach history disclosures.
CSP-03	Monitor CSP security advisories, breach disclosures, and relevant threat intelligence feeds. Any CSP breach or

CSP-04	security incident affecting ZOS data must trigger immediate notification to the IRT and initiation of the Incident Response Plan. Enforce ZOS identity standards on all CSP platforms: Okta SSO integration required where technically feasible; MFA mandatory for all ZOS user accounts; FIDO2 authentication required for all privileged access; Zscaler CASB applied to monitor and control cloud application usage.
CSP-05	Verify that all ZOS data stored in CSP environments is encrypted at rest using AES-256 and in transit using TLS 1.3. Encryption key management must ensure ZOS retains control of encryption keys for sensitive data.

7. Data Classification and CSP Tier Assignment

ZOS Data Classification	CSP Tier
Mission Critical (satellite command and telemetry data)	Tier 1
Confidential (personnel data, financial data, client contracts)	Tier 1
Internal (general business operations)	Tier 2
Public (marketing content, public-facing websites)	Tier 3

8. CSP Offboarding Requirements

When a cloud service relationship is terminated, the following steps must be completed before contract expiration:

- Certified data deletion or data retrieval confirmation from the CSP covering all ZOS data including backups, logs, and derived data.
- Revocation of all ZOS user accounts, API keys, and integration credentials on the CSP platform.
- Removal of the CSP from the Okta SSO configuration and Zscaler CASB policy.

- Documentation of offboarding completion in the cloud service inventory, including the date of data deletion certification.
- Legal review to confirm all DPA obligations have been fulfilled by the CSP.

9. Legal and Regulatory Obligations

Framework	Relevance
NIST SP 800-53 Rev 5	SA-9 (External System Services), SA-12 (Supply Chain Risk Management)
NIST CSF 2.0	Govern (GV.SC) Supply Chain Risk Management; Protect (PR.AC) Access Control
FedRAMP Authorization Framework	Required for CSPs handling data related to ZOS defense client obligations
CIS Controls v8	Control 3 (Data Protection), Control 16 (Application Software Security)
ISO/IEC 27001:2022	Annex A.5.19 (Information security in supplier relationships)
GDPR and TDP SA	Data processor requirements for any CSP processing personal data of ZOS employees or clients
CMMC Level 2	Supply chain risk management practices for defense contractor obligations

10. Sources and References

- SANS/CRF Cloud Service Provider Management Policy Template (Feb 2026). <https://www.sans.org/information-security-policy/cloud-service-provider-management-policy>
- CIS Controls v8. <https://www.cisecurity.org/controls/v8>
- NIST SP 800-53 Rev 5. <https://csrc.nist.gov>
- NIST CSF 2.0. <https://www.nist.gov/cyberframework>
- FedRAMP Authorization Framework. <https://www.fedramp.gov>
- ISO/IEC 27001:2022. <https://www.iso.org/standard/82875.html>
- Flexera 2025 State of the Cloud Report. <https://www.flexera.com>